



COMPLYAN

COMPLYAN INSIGHTS

ISO 27001 Checklist

14-Step Implementation Guide

www.complyan.com



ISO 27001 certification is becoming increasingly common as businesses enter global markets. However, first-time certification can be challenging.

To help, we've created a concise ISO 27001 checklist highlighting the key steps to achieve compliance.

Step 1: Appoint an ISO 27001 Team

- ☐ Define roles, responsibilities, and timelines for the certification process.
 - ☐ Determine the scope of your ISMS and consult with company leadership.
-

Step 2: Develop and Publish ISMS Policies and Documents

- ☐ Create a framework for establishing, implementing, maintaining, and improving the ISMS.
- ☐ Work with senior management to establish an information security policy focused on protecting the confidentiality, integrity, and availability of information assets.
- ☐ Include references to supporting documentation such as:
 - ☐ Information Security Objectives
 - ☐ Leadership and Commitment
 - ☐ Roles, Responsibilities, and Authorities
 - ☐ Risk Assessment and Treatment Approach
 - ☐ Control of Documented Information
 - ☐ Communication Procedures
 - ☐ Internal Audit Processes
 - ☐ Management Review Procedures
 - ☐ Corrective Actions and Continual Improvement
 - ☐ Policy Violations
- ☐ Finalize and publish these policies for employee review.

Step 3: Conduct a Risk Assessment

- ☐ Establish a risk management framework.
 - ☐ Identify potential information security risks.
 - ☐ Assess the likelihood and impact of each risk.
 - ☐ Rank risks based on their likelihood and impact.
 - ☐ Develop a response plan for each risk and assign an owner.
-

Step 4: Complete a Statement of Applicability

- ☐ Review the 93 controls in Annex A.
 - ☐ Select controls to address identified risks using ISO 27002 as a guide.
 - ☐ Document the Statement of Applicability, listing all Annex A controls and justifying the inclusion or exclusion of each.
-

Step 5: Implement ISMS Policies and Controls

- ☐ Create a communication plan to inform staff of changes and progress.
 - ☐ Share policies and track employee review.
 - ☐ Monitor and assess the effectiveness of the controls.
-

Step 6: Train Team Members on ISO 27001

- ☐ Conduct regular training sessions to ensure awareness of new policies and procedures.
- ☐ Define personnel expectations for maintaining the ISMS.
- ☐ Educate staff on common threats and appropriate responses.
- ☐ Establish disciplinary processes for violations of information security requirements.

Step 7: Gather Documentation and Evidence

- ☐ Prepare a list of required ISO 27001 documents and records for audit reference.
-

Step 8: Conduct an Internal Audit

- ☐ Define the scope and methodology, covering Clauses 4-10 and relevant Annex A controls.
 - ☐ Select an independent and objective internal auditor.
 - ☐ Document audit results and address any findings.
-

Step 9: Undergo a Stage 1 Audit

- ☐ Choose an accredited ISO 27001 auditor.
 - ☐ Conduct a Stage 1 audit focusing on documentation review to evaluate ISMS design and readiness for Stage 2.
-

Step 10: Implement Stage 1 Audit Advice

- ☐ Address all ISO 27001 requirements and ensure compliance with documented processes and third-party contractual obligations.
 - ☐ Record and rectify any nonconformities identified.
-

Step 11: Undergo a Stage 2 Audit

- ☐ Conduct a Stage 2 audit to test ISMS design, functionality, implementation, and operation of Clauses 4-10 and relevant Annex A controls.

Step 12: Implement Stage 2 Audit Advice

- ☐ Ensure all ISO 27001 requirements are met and the organization follows documented processes and third-party contractual obligations.
 - ☐ Address any nonconformities identified by the auditor.
-

Step 13: Commit to Subsequent Audits and Assessments

- ☐ Conduct quarterly or bi-annual management reviews.
 - ☐ Prepare for first and second-year surveillance audits.
 - ☐ Perform annual risk assessments and internal audits.
 - ☐ Prepare for the year three recertification audit to maintain ISMS effectiveness.
-

Step 14: Perform Ongoing Improvements

- ☐ Identify and address weaknesses and threats to the ISMS.
- ☐ Document and track nonconformities and their remediation.

Simplify your ISO 27001 audit with Complyan's automated risk assessments, policy management, and incident reporting.

Streamline compliance, reduce risks, and boost efficiency with our centralized SaaS platform.

Global Marketplace

Cybersecurity and Data Governance Frameworks



National and Sector-Level Frameworks



Time and resource savings

Complyan automates many of the time-consuming and repetitive tasks associated with ISO 27001 compliance, such as risk assessments and policy management. This saves organizations time and resources, allowing them to focus on other business areas.



Increased efficiency

Complyan provides a centralized platform for managing all aspects of information security, making it easier for organizations to see their current compliance status, identify areas for improvement, implement necessary changes, and continuously monitor for changes. This increases the efficiency of their compliance efforts and helps ensure they are always up-to-date with the latest standards and best practices.



Improved compliance posture

By using Complyan, organizations can demonstrate their commitment to information security and improve their overall compliance posture by having holistic visibility and control over their information assets and endpoints. This helps meet the requirements and best practices of ISO 27001 and build trust with customers, partners, and other interested parties.

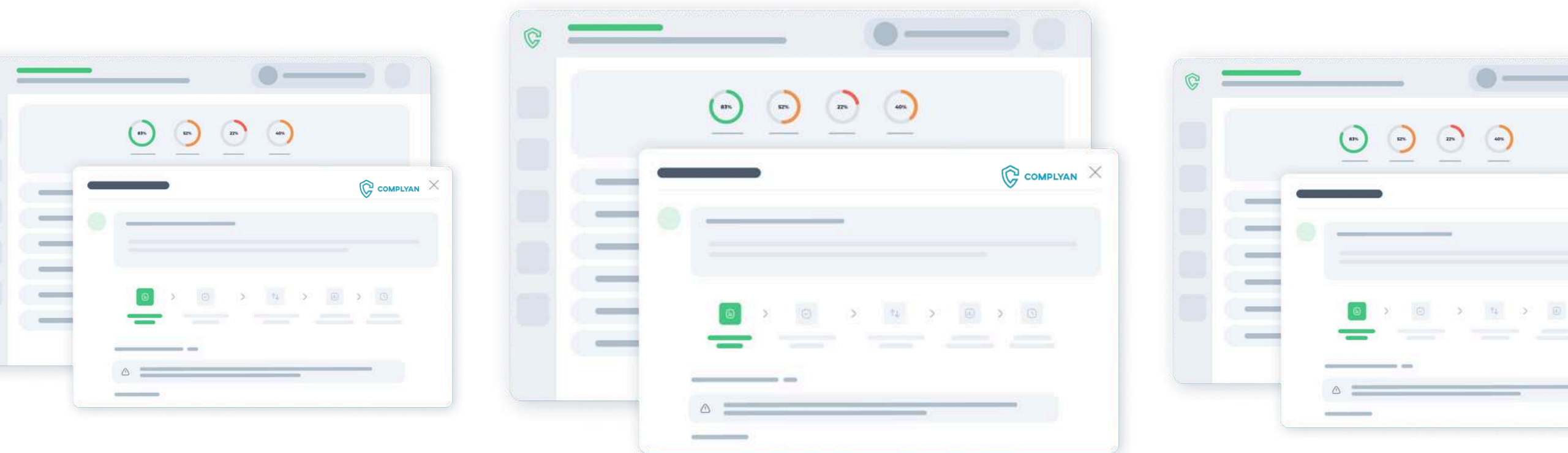


Regular updates

Complyan provides regular updates to ensure that its users are always up-to-date with the latest standards and best practices. This helps organizations stay ahead of the curve and remain compliant with the latest developments in the world of information security.

Streamline Cybersecurity and Data Privacy Compliance with Complyan

- ✓ Assess your level of compliance towards cybersecurity standards and frameworks.
- ✓ Streamline compliance with multiple frameworks and standards with controls mapping.
- ✓ Single source of truth for stakeholders on your cybersecurity compliance journey.



Get Started !

info@complyan.com | +971 4 3383365

www.complyan.com